Quy trình xin cấp quyền hệ thống

Phiên bản: 1.0 | Ngày hiệu lực: 01/09/2025 | Đơn vị ban hành: Khối Công nghệ thông tin (giả định)

1. Thông tin kiểm soát tài liệu

Mục	Nội dung
Mã tài liệu	SYN-P09
Đơn vị sở hữu	Khối Công nghệ thông tin (giả định)
Người phê duyệt	Trưởng khối Công nghệ thông tin (giả định)
Đối tượng áp dụng	Toàn bộ nhân sự cần quyền truy cập hệ thống nội bộ, quản lý trực tiếp và IT Helpdesk
Phân loại	Nội bộ
Ghi chú	Tài liệu giả lập để kiểm thử, không phải quy trình VSF đã xác nhận

Quy trình này quy định cách nhân sự xin quyền truy cập vào các hệ thống nội bộ của công ty. Mọi quyền truy cập đều phải có yêu cầu bằng form, có lý do công việc và có phê duyệt của quản lý trực tiếp trước khi IT cấp.

2. Mục đích, phạm vi và đối tượng

2.1 Mục đích

Quy trình bảo đảm nguyên tắc cấp quyền tối thiểu: mỗi nhân sự chỉ có quyền cần thiết cho công việc của mình, quyền được cấp có người chịu trách nhiệm phê duyệt và có dấu vết để kiểm tra khi cần. Quy trình cũng giúp nhân sự biết chính xác cần làm gì, gửi ở đâu và chờ bao lâu để có quyền.

2.2 Phạm vi áp dụng

Quy trình áp dụng cho việc xin cấp mới hoặc điều chỉnh quyền truy cập vào hệ thống nội bộ, ứng dụng nghiệp vụ, kho dữ liệu và công cụ làm việc của đội. Quy trình không áp dụng cho việc kích hoạt tài khoản công ty lần đầu, phần đó thuộc Hướng dẫn kích hoạt tài khoản và cài VPN, và không áp dụng cho việc cài phần mềm lên máy, phần đó thuộc Quy trình yêu cầu cài phần mềm và kiểm tra VinSOC.

2.3 Đối tượng áp dụng

- Nhân sự cần quyền vào một hệ thống cho công việc.
- Quản lý trực tiếp, người xem xét và phê duyệt yêu cầu trên cổng.
- IT Helpdesk, đơn vị cấp quyền sau khi có phê duyệt.

2.4 Tài liệu liên quan

- Hướng dẫn kích hoạt tài khoản và cài VPN: tài khoản phải hoạt động trước khi xin quyền.
- Chính sách phân loại dữ liệu: mức độ nhạy cảm của dữ liệu ảnh hưởng tới việc xin quyền.
- Chính sách mật khẩu và xác thực: bảo vệ tài khoản đã được cấp quyền.
- Quy trình báo cáo sự cố bảo mật: xử lý khi nghi ngờ quyền bị lạm dụng.
- Danh bạ đầu mối theo đội: kênh liên hệ của IT Helpdesk.

3. Định nghĩa và thuật ngữ

Thuật ngữ	Ý nghĩa trong tài liệu này
Quyền hệ thống	Khả năng truy cập, xem, chỉnh sửa hoặc quản trị một hệ thống, ứng dụng hoặc kho dữ liệu nội bộ.
IT-ACC-01	Mã form Yêu cầu cấp quyền hệ thống trên cổng IT.
Cổng IT	Trang yêu cầu hỗ trợ của IT tại https://it.vsf-demo.example/requests.
Mức quyền	Mức độ quyền được xin, gồm Đọc, Ghi hoặc Quản trị.
Quản lý trực tiếp	Người quản lý phụ trách công việc của nhân sự, người phê duyệt yêu cầu quyền trên cổng.
Phê duyệt	Xác nhận của quản lý trực tiếp trên cổng rằng quyền được xin là cần thiết cho công việc.
Hàng đợi IT	Danh sách các yêu cầu đã đủ điều kiện và đang chờ IT xử lý.
Nguyên tắc cấp quyền tối thiểu	Chỉ cấp quyền vừa đủ để làm việc, không cấp rộng hơn nhu cầu.
Ngày làm việc	Ngày làm việc theo lịch của công ty, không tính thứ Bảy, Chủ nhật và ngày nghỉ lễ.

4. Vai trò và trách nhiệm

Vai trò	Trách nhiệm chính	Đầu ra
Nhân sự	Xác định đúng hệ thống và mức quyền cần thiết, gửi form IT-ACC-01 đủ thông tin.	Yêu cầu đã gửi
Quản lý trực tiếp	Xem xét lý do công việc, phê duyệt hoặc từ chối yêu cầu trên cổng.	Kết quả phê duyệt
IT Helpdesk	Kiểm tra yêu cầu đã có phê duyệt, cấp quyền trong 2 ngày làm việc sau khi được phê duyệt, thông báo kết quả.	Quyền đã cấp
Chủ sở hữu hệ thống	Cung cấp thông tin về mức quyền và điều kiện truy cập khi IT cần hỏi.	Thông tin xác nhận

5. Nguyên tắc

- Mọi yêu cầu quyền đều phải tạo bằng form IT-ACC-01 trên cổng IT.
- Yêu cầu phải nêu hệ thống cần truy cập và lý do.
- Quản lý trực tiếp phê duyệt yêu cầu trên cổng. Yêu cầu không có phê duyệt của quản lý sẽ bị từ chối.
- IT cấp quyền trong 2 ngày làm việc sau khi được phê duyệt.
- Không xin quyền trực tiếp qua chat hoặc email.
- Chỉ xin mức quyền cần thiết, không xin quyền quản trị khi chỉ cần quyền đọc.

6. Quy trình chi tiết

6.1 Các bước tóm tắt

1. Tạo yêu cầu bằng form IT-ACC-01 trên cổng IT, nêu hệ thống cần truy cập và lý do.
2. Quản lý trực tiếp phê duyệt yêu cầu trên cổng.
3. IT cấp quyền trong 2 ngày làm việc sau khi được phê duyệt.

6.2 Bước 1: chuẩn bị thông tin

Trước khi gửi yêu cầu, nhân sự xác định tên hệ thống cần truy cập, mức quyền cần thiết và nhiệm vụ cụ thể cần dùng quyền đó. Nhân sự cũng cần có sẵn địa chỉ email công ty của quản lý trực tiếp để điền vào form. Nếu chưa chắc mức quyền nào là phù hợp, nhân sự hỏi quản lý trực tiếp hoặc đồng nghiệp trong đội trước khi gửi.

6.3 Bước 2: tạo yêu cầu bằng form IT-ACC-01

Nhân sự mở cổng IT tại https://it.vsf-demo.example/requests, chọn form IT-ACC-01 và điền các trường như bảng dưới đây.

Trường	Tên hiển thị	Bắt buộc	Cách điền
employee_id	Mã nhân viên	Có	Nhập mã nhân viên do HR cấp.
system_name	Hệ thống cần truy cập	Có	Ghi đúng tên hệ thống hoặc ứng dụng cần quyền.
access_level	Mức quyền	Có	Chọn một trong ba mức: Đọc, Ghi hoặc Quản trị.
business_reason	Lý do	Có	Nêu nhiệm vụ cụ thể cần dùng quyền, không viết chung chung.
manager_email	Email quản lý phê duyệt	Có	Nhập email công ty của quản lý trực tiếp.

Ba mức quyền được hiểu như sau. Quyền Đọc cho phép xem dữ liệu, không thay đổi. Quyền Ghi cho phép thêm hoặc chỉnh sửa dữ liệu trong phạm vi được cấp. Quyền Quản trị cho phép thay đổi cấu hình hoặc phân quyền cho người khác và chỉ được xem xét khi lý do công việc thực sự yêu cầu.

6.4 Bước 3: quản lý trực tiếp phê duyệt trên cổng

Sau khi nhân sự gửi form, yêu cầu được chuyển tới quản lý trực tiếp có tên trong trường email quản lý phê duyệt. Quản lý xem xét lý do, mức quyền và phê duyệt hoặc từ chối trên cổng. Phê duyệt phải được thực hiện trên cổng để có dấu vết. Phê duyệt bằng lời, bằng tin nhắn chat hoặc bằng email không được IT chấp nhận. Yêu cầu không có phê duyệt của quản lý sẽ bị từ chối.

6.5 Bước 4: IT cấp quyền

Khi yêu cầu đã được phê duyệt, yêu cầu vào hàng đợi của IT. IT cấp quyền trong 2 ngày làm việc sau khi được phê duyệt. IT đối chiếu mã nhân viên, hệ thống, mức quyền và người phê duyệt rồi thực hiện cấp. Nếu hệ thống do đội khác quản lý, IT phối hợp với chủ sở hữu hệ thống và thông báo cho nhân sự khi có tiến triển.

6.6 Bước 5: xác nhận và sử dụng

IT thông báo cho nhân sự khi quyền đã được cấp. Nhân sự đăng nhập thử để bảo đảm quyền hoạt động đúng. Nếu quyền không đúng như yêu cầu, nhân sự báo lại IT Helpdesk trên cùng yêu cầu, không tạo một yêu cầu mới cho cùng nội dung.

6.7 Bảng thời gian xử lý

Bước	Người thực hiện	Thời hạn
Gửi form IT-ACC-01	Nhân sự	Bất kỳ lúc nào trên cổng IT
Phê duyệt trên cổng	Quản lý trực tiếp	Theo trạng thái trên cổng, cần có trước khi IT xử lý
Cấp quyền	IT	2 ngày làm việc sau khi được phê duyệt
Thông báo kết quả	IT	Ngay khi cấp xong

Thời hạn 2 ngày làm việc chỉ bắt đầu tính từ thời điểm quản lý phê duyệt, không tính từ lúc nhân sự gửi form. Vì vậy nhân sự nên nhắc quản lý phê duyệt sớm để rút ngắn tổng thời gian chờ.

7. Hướng dẫn cho quản lý trực tiếp khi phê duyệt

Quản lý trực tiếp là chốt kiểm soát quan trọng nhất của quy trình. Phê duyệt không chỉ là bấm đồng ý mà là xác nhận rằng nhân sự thực sự cần quyền đó cho công việc hiện tại. Quản lý nên tự trả lời các câu hỏi dưới đây trước khi phê duyệt.

- Nhân sự có nhiệm vụ nào cần quyền này trong thời gian tới không.
- Mức quyền được xin có vượt quá nhu cầu không, ví dụ xin quyền Ghi trong khi chỉ cần xem dữ liệu.
- Hệ thống chứa loại dữ liệu nào và nhân sự có được phép tiếp cận loại dữ liệu đó theo Chính sách phân loại dữ liệu không.
- Quyền cần dùng lâu dài hay chỉ trong một khoảng thời gian, để ghi rõ trong lý do.
- Nhân sự đã hoàn thành các nội dung đào tạo an toàn thông tin cần thiết chưa.

Nếu chưa đồng ý, quản lý có thể từ chối và ghi rõ lý do trên cổng để nhân sự điều chỉnh yêu cầu. Quản lý không phê duyệt các yêu cầu do chính mình lập hoặc yêu cầu của người mà mình không quản lý trực tiếp. Trong trường hợp quản lý vắng mặt kéo dài, đơn vị cần chỉ định người thay thế theo quy định của đơn vị và thông báo cho IT Helpdesk.

8. Ví dụ tình huống minh họa

8.1 Tình huống 1: xin quyền xem báo cáo

Một nhân sự mới cần xem báo cáo tuần của đội để nắm tình hình dự án. Nhân sự gửi form IT-ACC-01, nhập tên hệ thống báo cáo, chọn mức quyền Đọc, nêu lý do là cần nắm số liệu để chuẩn bị nhiệm vụ đầu tiên và nhập email quản lý. Quản lý phê duyệt trên cổng. IT cấp quyền trong 2 ngày làm việc sau khi được phê duyệt và thông báo cho nhân sự.

8.2 Tình huống 2: xin quyền Quản trị không cần thiết

Một nhân sự chọn mức quyền Quản trị vì nghĩ rằng quyền cao hơn sẽ tiện hơn. Quản lý thấy nhiệm vụ của nhân sự chỉ cần chỉnh sửa dữ liệu nên từ chối yêu cầu và đề nghị chọn mức Ghi. Nhân sự gửi lại yêu cầu mới với mức quyền phù hợp. Cách làm này giúp giữ nguyên tắc cấp quyền tối thiểu.

8.3 Tình huống 3: xin quyền qua chat

Một nhân sự nhắn tin trực tiếp cho nhân viên IT để nhờ cấp quyền nhanh. Nhân viên IT không xử lý và hướng dẫn nhân sự tạo yêu cầu bằng form IT-ACC-01 trên cổng IT. Nhân sự tạo yêu cầu, quản lý phê duyệt trên cổng và IT cấp quyền theo thời hạn. Việc xin quyền qua chat không được chấp nhận vì không có dấu vết và không có phê duyệt.

8.4 Tình huống 4: hệ thống do đội khác quản lý

Nhân sự cần quyền vào hệ thống do một đội khác quản lý. Sau khi quản lý trực tiếp phê duyệt, IT phối hợp với chủ sở hữu hệ thống để xác nhận mức quyền. Trong thời gian này IT có thể hỏi thêm thông tin. Nhân sự trả lời trên yêu cầu hiện có để không làm gián đoạn quy trình.

9. Rà soát và thu hồi quyền

Quyền hệ thống không nên tồn tại vô thời hạn khi không còn nhu cầu. IT phối hợp với quản lý và chủ sở hữu hệ thống định kỳ rà soát quyền đang có, đối chiếu với nhiệm vụ hiện tại của nhân sự. Quyền không còn cần thiết được thu hồi và IT thông báo cho nhân sự.

- Khi nhân sự chuyển đội hoặc đổi vai trò, quản lý cũ và quản lý mới cùng rà soát quyền.
- Khi nhân sự nghỉ việc, IT thu hồi toàn bộ quyền trong quá trình bàn giao.
- Khi kết thúc dự án ngắn hạn, quyền tạm thời được thu hồi theo thời gian đã ghi trong lý do.
- Khi phát hiện quyền bị lạm dụng, IT tạm khóa quyền và chuyển sang xử lý theo Quy trình báo cáo sự cố bảo mật.

10. Điều kiện, ngoại lệ và những việc không được làm

10.1 Điều kiện để yêu cầu được xử lý

- Tài khoản công ty của nhân sự đã được kích hoạt.
- Form IT-ACC-01 đủ các trường bắt buộc.
- Quản lý trực tiếp đã phê duyệt trên cổng.
- Lý do công việc đủ rõ để IT và chủ sở hữu hệ thống đánh giá.

10.2 Ngoại lệ

- Quyền tạm thời cho một dự án ngắn hạn: nhân sự nêu rõ thời gian cần dùng trong phần lý do để IT ghi nhận và thu hồi khi kết thúc.
- Nhân sự chuyển đội: quản lý mới phê duyệt yêu cầu mới, còn quyền cũ do IT và quản lý cũ xem xét thu hồi.
- Quản lý trực tiếp vắng mặt: nhân sự hỏi HR Onboarding hoặc IT Helpdesk về người có thẩm quyền thay thế, không nhờ người khác phê duyệt bằng chat.

10.3 Những việc không được làm

- Không xin quyền trực tiếp qua chat hoặc email.
- Không dùng tài khoản của đồng nghiệp để truy cập hệ thống khi chưa có quyền.
- Không nhờ đồng nghiệp chia sẻ mật khẩu hoặc ảnh chụp màn hình dữ liệu để thay cho quyền.
- Không xin mức quyền cao hơn nhu cầu để tiện dùng về sau.
- Không gửi yêu cầu khi chưa có lý do công việc rõ ràng.
- Không tự phê duyệt yêu cầu của chính mình.

11. Lỗi thường gặp và cách xử lý

Tình huống	Nguyên nhân thường gặp	Cách xử lý
Yêu cầu bị từ chối	Không có phê duyệt của quản lý	Nhờ quản lý phê duyệt trên cổng rồi gửi lại yêu cầu
Yêu cầu bị trả lại	Thiếu hệ thống, lý do hoặc email quản lý	Bổ sung thông tin rồi gửi lại
Chưa thấy quyền sau khi được phê duyệt	Chưa đủ 2 ngày làm việc hoặc đang chờ chủ sở hữu hệ thống	Kiểm tra trạng thái trên cổng, hỏi IT Helpdesk nếu quá thời hạn
Quyền cấp không đủ để làm việc	Chọn mức quyền thấp hơn nhu cầu	Gửi yêu cầu điều chỉnh mức quyền có phê duyệt mới
Quản lý không nhận được yêu cầu để duyệt	Email quản lý nhập sai	Sửa lại trường email quản lý phê duyệt
Không đăng nhập được sau khi được cấp quyền	Chưa đăng xuất hoặc chưa hoàn tất xác thực	Đăng xuất, đăng nhập lại, nếu vẫn lỗi thì báo IT Helpdesk
Có người gửi tin nhắn hứa cấp quyền nhanh	Giả mạo nhân viên IT	Không phản hồi, báo IT Helpdesk và Trực SOC nếu đã lộ thông tin

12. Checklist

12.1 Checklist của nhân sự

- Tài khoản đã được kích hoạt và đăng nhập được.
- Đã xác định đúng hệ thống, mức quyền và lý do công việc.
- Đã có email công ty của quản lý trực tiếp.
- Đã gửi form IT-ACC-01 trên cổng IT.
- Đã nhắc quản lý phê duyệt trên cổng.
- Không xin quyền qua chat hoặc email.

12.2 Checklist của quản lý trực tiếp

- Đã đọc lý do và mức quyền trong yêu cầu.
- Đã đối chiếu quyền với nhiệm vụ thực tế của nhân sự.
- Đã phê duyệt hoặc từ chối trên cổng, không phản hồi bằng chat.
- Đã yêu cầu điều chỉnh mức quyền nếu thấy cao hơn nhu cầu.

12.3 Checklist của IT Helpdesk

- Yêu cầu đã có phê duyệt của quản lý trên cổng.
- Đã đối chiếu mã nhân viên, hệ thống và mức quyền.
- Đã cấp quyền trong 2 ngày làm việc sau khi được phê duyệt.
- Đã thông báo kết quả cho nhân sự.

13. Mẫu nội dung yêu cầu

Mẫu điền form IT-ACC-01: Mã nhân viên: điền mã của bạn. Hệ thống cần truy cập: điền tên hệ thống. Mức quyền: Đọc. Lý do: cần xem báo cáo của đội để chuẩn bị nội dung cho nhiệm vụ đang được giao. Email quản lý phê duyệt: email công ty của quản lý trực tiếp.

Mẫu tin nhắn nhắc quản lý phê duyệt, gửi qua kênh công việc thông thường và chỉ mang tính nhắc nhở: Tôi vừa gửi yêu cầu IT-ACC-01 trên cổng IT để xin quyền vào hệ thống phục vụ nhiệm vụ đang làm. Nhờ anh hoặc chị xem và phê duyệt trên cổng khi thuận tiện. Việc phê duyệt phải được thực hiện trên cổng, không phải trong tin nhắn này.

Mẫu email hỏi trạng thái gửi it-helpdesk@vsf-demo.example: Kính gửi IT Helpdesk, yêu cầu IT-ACC-01 của tôi đã được quản lý phê duyệt trên cổng. Nhờ IT cho biết tiến độ cấp quyền. Trân trọng.

14. Câu hỏi thường gặp

Hỏi: Tôi xin quyền vào hệ thống như thế nào? Đáp: Tạo yêu cầu bằng form IT-ACC-01 trên cổng IT, nêu hệ thống cần truy cập và lý do.

Hỏi: Ai phê duyệt yêu cầu quyền của tôi? Đáp: Quản lý trực tiếp phê duyệt yêu cầu trên cổng.

Hỏi: IT cấp quyền trong bao lâu? Đáp: IT cấp quyền trong 2 ngày làm việc sau khi được phê duyệt.

Hỏi: Tôi có thể nhắn IT qua chat để xin quyền cho nhanh không? Đáp: Không. Không xin quyền trực tiếp qua chat hoặc email.

Hỏi: Nếu quản lý chưa phê duyệt thì sao? Đáp: Yêu cầu không có phê duyệt của quản lý sẽ bị từ chối, nên nhân sự cần nhờ quản lý phê duyệt trên cổng.

Hỏi: Form IT-ACC-01 có những mức quyền nào? Đáp: Ba mức là Đọc, Ghi và Quản trị.

Hỏi: Phê duyệt bằng email hoặc tin nhắn có được không? Đáp: Không. Phê duyệt phải được thực hiện trên cổng.

Hỏi: Tôi đổi sang đội khác thì quyền cũ ra sao? Đáp: Quản lý mới phê duyệt yêu cầu mới, còn quyền cũ do IT và quản lý cũ xem xét thu hồi.

Hỏi: Tài khoản chưa kích hoạt thì có xin quyền được không? Đáp: Chưa. Nhân sự cần kích hoạt tài khoản trước theo Hướng dẫn kích hoạt tài khoản và cài VPN.

15. Lịch sử sửa đổi

Phiên bản	Ngày hiệu lực	Nội dung thay đổi
1.0	01/09/2025	Ban hành quy trình xin cấp quyền hệ thống với form IT-ACC-01, bước phê duyệt của quản lý trực tiếp và bước cấp quyền của IT. Bản mở rộng bổ sung mô tả trường form, mức quyền, ngoại lệ, lỗi thường gặp, checklist và mẫu yêu cầu.